

Peta Permukaan Serangan — Bab 5 (Web Recon & Proxy Intersep)

1. Info Target

- **Aplikasi Target 1:** OWASP Juice Shop
 - **URL Dasar:** `http://localhost:3000`
- **Aplikasi Target 2:** OWASP WebGoat
 - **URL Dasar:** `http://localhost:8082/WebGoat`
- **Tanggal Pemetaan:** 2 Oktober 2026
- **Lingkungan Pengujian:** Kali Linux (Docker Environment)

2. Fingerprinting Teknologi

Komponen / Alat	OWASP Juice Shop (:3000)	OWASP WebGoat (:8082)
Platform / Runtime	Node.js (Express Framework)	Java (Spring Boot Framework)
Frontend UI	Angular, Material Design	HTML5, JSP / Thymeleaf, Bootstrap
Session Tracking	JSON Web Token (JWT) / <code>token</code>	Cookie Servlet <code>JSESSIONID</code>
Header Signifikan	<code>Access-Control-Allow-Origin: *</code> , <code>X-Content-Type-Options: nosniff</code>	<code>X-Frame-Options: DENY</code> , <code>Pragma: no-cache</code>

3. Daftar Endpoint Ditemukan (Observasi Manual via Proxy History)

Method	Endpoint	Fungsi (Dugaan)	Butuh Auth?	Catatan Teknis / Respons
POST	<code>/rest/user/login</code>	Otentikasi pengguna	Tidak	Menerima payload JSON <code>{email, password}</code>
GET	<code>/rest/products/search?q=</code>	Pencarian katalog produk	Tidak	Menerima query parameter, berpotensi input handling issue
GET	<code>/rest/admin/application-configuration</code>	Pengambilan config aplikasi	Tidak	Membocorkan parameter internal (<i>Information Disclosure</i>)

Method	Endpoint	Fungsi (Dugaan)	Butuh Auth?	Catatan Teknis / Respons
POST	/api/Users/	Pendaftaran akun baru	Tidak	Menangani registrasi entitas user baru
GET	/api/Challenges/	Metadata challenge lab	Tidak	Mengembalikan daftar status latihan
POST	/WebGoat/login	Otentikasi WebGoat	Tidak	Menangani login akun berbasis form session
GET	/WebGoat/start.mvc	Router utama dashboard	Ya	Mengarahkan ke modul pembelajaran WebGoat

4. Daftar Endpoint dari Content Discovery (ffuf)

Path	Status Code	Ukuran Response	Karakteristik / Catatan
/ftp	200 / 403	Bervariasi	Direktori file publik / berpotensi directory listing
/api-docs	200	Statis	Swagger UI dokumentasi API terekspos
/assets	200	Statis	Direktori aset statis publik (gambar, css, js)
/snippets	200	Statis	Direktori penyimpanan kode JavaScript

5. Spesifikasi API yang Ditemukan

- **Swagger / OpenAPI Bocor?:** Ya, aktif dan dapat diakses pada rute /api-docs dan /swagger.json pada Juice Shop.
- **GraphQL Endpoint Ditemukan?:** Tidak ditemukan (aplikasi dominan menggunakan RESTful API).
- **Introspection GraphQL Aktif?:** Tidak relevan.

6. Ringkasan & Area Prioritas Analisis

Berdasarkan pemetaan permukaan serangan di atas, area yang memiliki prioritas tinggi untuk dianalisis pada modul berikutnya meliputi:

1. **Dokumentasi API Terbuka (/api-docs):** Memberikan visibilitas penuh terhadap semua rute tersembunyi, skema database, dan validasi tipe data backend tanpa otentikasi.
2. **Parameter Input Langsung (/rest/products/search?q=):** Endpoint publik yang memproses input teks langsung dari pengguna dan menjadi kandidat utama evaluasi sanitasi query.
3. **Endpoint Konfigurasi Terbuka (/rest/admin/application-configuration):** Paparan endpoint manajemen tanpa pembatasan hak akses (*Broken Access Control*).